

C49: Validaciones a todos los endpoints de Incidentes

Type	Priority	Estimate	References
Functional	High	None	None
AI Automated Test	Automation Type	Is Automated	
None	None	No	
Labels			
Integridad de datos Validaciones			

Preconditions

1. El sistema debe validar estrictamente la integridad de los datos, la asignación de áreas y las restricciones de seguridad por rol antes de procesar cualquier flujo de incidentes.
2. Se deben contemplar tanto escenarios positivos (flujo ideal) como escenarios negativos (control de errores y seguridad).

Steps

1. Validar integridad en la creación de Incidentes:
 - a. Intentar registrar un incidente asignando un operador nulo o inexistente.
 - b. Intentar registrar un incidente utilizando un token de autenticación que no pertenezca al rol de Operador (ej. Admin, Supervisor o Técnico).
2. Validar reglas de negocio en la asignación de tareas:
 - a. Intentar asignar un incidente a usuarios con roles distintos a "Técnico" (ej. asignar a un Admin o a otro Supervisor).
 - b. Verificar si el Supervisor puede consultar la lista de usuarios pertenecientes exclusivamente a su misma área organizacional.
3. Validar filtros y propiedad de datos (Método GET/PATCH):
 - a. Realizar peticiones 'GET /incidentes' con tokens de Supervisor y Técnico para verificar si la respuesta filtra automáticamente los incidentes por su área correspondiente.
 - b. Intentar modificar o actualizar el estado de un incidente asignado a "Técnico A" utilizando el token de autenticación de un "Técnico B".
4. Validar gestión de credenciales administrativa:
 - a. Verificar la existencia y el funcionamiento de un endpoint exclusivo para que los roles de gestión (Admin/Supervisor) puedan restablecer la contraseña de un usuario mediante su ID (ej. /users/{id}/change-password).
5. Evaluar la claridad de las respuestas del servidor (Mensajes de error personalizados).

Expected Result

El backend debe aplicar una lógica estricta basada en el diseño del sistema y responder de la siguiente manera:

1. Control de Incidentes y Operadores: El sistema NO debe permitir la creación de incidentes con operadores nulos ni por usuarios que no tengan el rol de Operador (debe retornar un error de validación). Actualmente, esto falla permitiendo datos nulos y accesos globales debido al bloqueo del rol operador.
2. Restricción de Asignación y Áreas: Los incidentes solo deben poder asignarse a usuarios con rol de Técnico. Asimismo, el Supervisor debe poder visualizar únicamente a los usuarios de su área, y las consultas GET de incidentes deben venir filtradas estrictamente por el área del Técnico/Supervisor que consulta.
3. Propiedad y Seguridad: Un técnico no debe tener autorización para modificar incidentes ajenos.
4. Endpoint de Soporte: Debe existir el endpoint funcional para el cambio de contraseñas por parte de los administradores/supervisores para cumplir con las tareas de gestión de accesos.
5. Mensajes de Error Personalizados y Descriptivos: Ante cualquier intento de violación de estas reglas (pasos del 1 al 3), el servidor NO debe devolver respuestas genéricas, sino mensajes personalizados detallando la razón exacta del fallo. Ejemplo: "Operación rechazada: Usted es un supervisor, esta tarea le corresponde a un técnico" o "Acción denegada: No tiene permisos para asignar técnicos".

